



案例特训专题

【安全篇】



课程内容提要

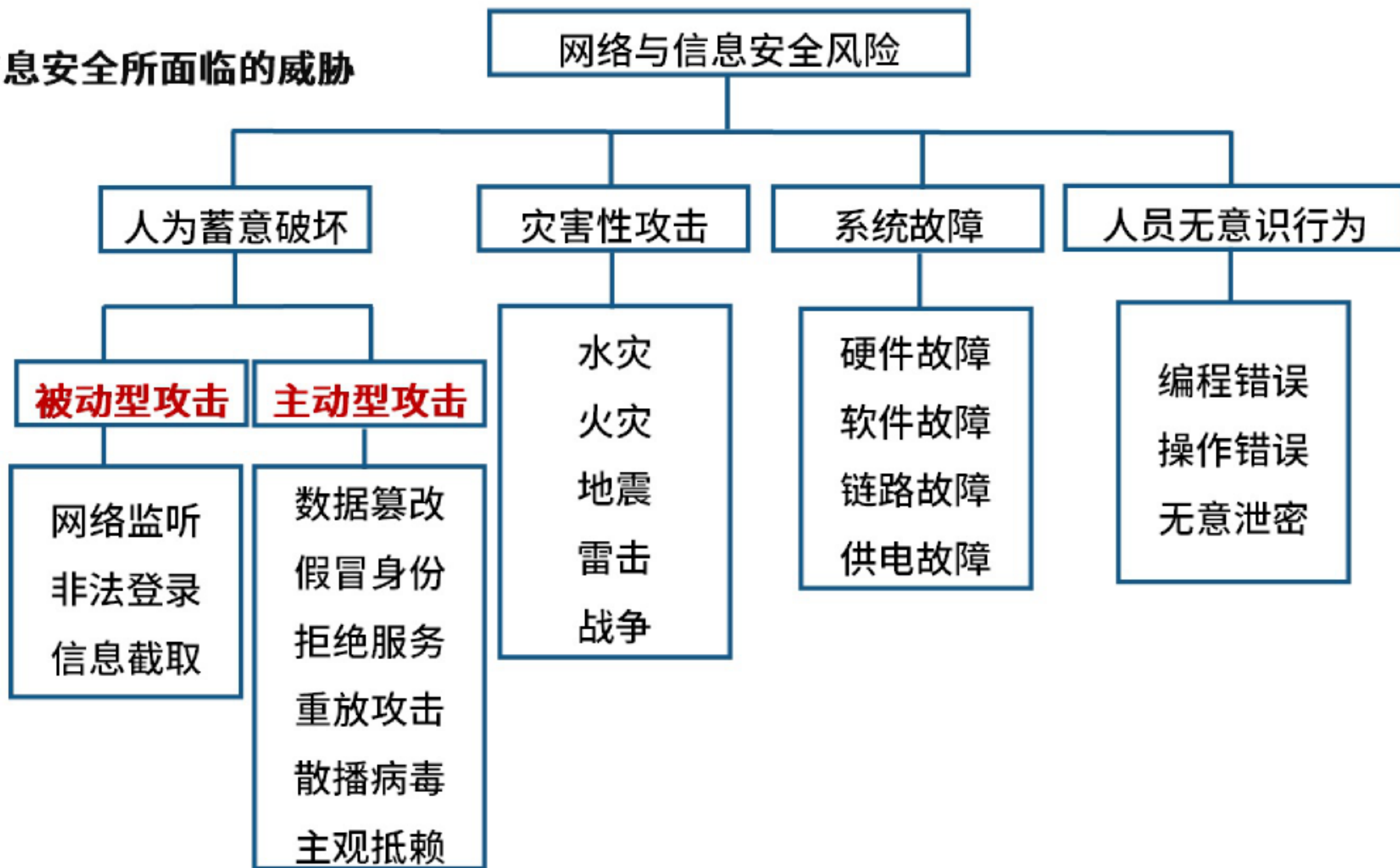


- 安全架构概述 (★★)
- 安全模型 (★★★★)
- 信息安全整体架构设计
- 网络安全体系架构设计
- 区块链技术 (★★)
- 案例分析练习题



安全架构概述

◆ 信息安全所面临的威胁





安全架构概述



被动攻击：**收集信息为主**，破坏保密性。

主动攻击：主动攻击的类别主要有：中断（破坏可用性），篡改（破坏完整性），伪造（破坏真实性）。

攻击类型	攻击名称	描述
被动攻击	窃听（网络监听）	用各种可能的合法或非法的手段窃取系统中的 信息资源和敏感信息 。
	业务流分析	通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。
	非法登录	有些资料将这种方式归为被动攻击方式。



安全架构概述



攻击类型	攻击名称	描述
主动攻击	假冒身份	非法用户冒充成为合法用户，特权小的用户冒充成为特权大的用户。
	抵赖	否认自己曾经发布过的某条消息、伪造一份对方来信等。
	旁路控制 【旁路攻击】	密码学中是指绕过对加密算法的繁琐分析，利用密码算法的硬件实现的运算中泄露的信息。如执行时间、功耗、电磁辐射等，结合统计理论快速的破解密码系统。
	重放攻击	所截获的某次合法的通信数据拷贝，出于非法的目的而被重新发送。 加【时间戳】能识别并应对重放攻击。
	拒绝服务（DOS）	破坏服务的【可用性】，对信息或其他资源的合法访问被无条件的阻止。



安全架构概述



攻击类型	攻击名称	描述
主动攻击	XSS跨站脚本攻击	通过利用网页【 开发时留下的漏洞 】，通过巧妙的方法注入恶意指令代码到网页。
	CSRF跨站请求伪造攻击	攻击者通过一些技术手段欺骗用户的浏览器与访问一个自己曾经认证过的网站并执行一些操作（如转账或购买商品等）。
	缓冲区溢出攻击	利用【 缓冲区溢出漏洞 】所进行的攻击。在各种操作系统、应用软件中广泛存在。
	SQL注入攻击	攻击者把SQL命令插入到Web表单，欺骗服务器执行恶意的SQL命令。 SQL注入攻击的方式 ：【恶意拼接查询】、【利用注释执行非法命令】、【传入非法参数】、【添加额外条件】。 抵御SQL攻击的方式 包括：【使用正则表达式】、【使用参数化的过滤性语句】、【检查用户输入的合法性】、【用户相关数据加密处理】、【存储过程来执行查询】、【使用专业的漏洞扫描工具】。



习题讲解



以下网络攻击中，（ ）属于被动攻击。

- A、拒绝服务攻击
- B、重放
- C、假冒
- D、网络监听



习题讲解



信息系统面临多种类型的网络安全威胁。其中，信息泄露是指信息被泄露或透露给某个非授权的实体；（ ）是指数据被非授权地进行修改；（ ）是指对信息或其他资源的合法访问被无条件地阻止；（ ）是指通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。

- | | | | |
|---------|------------|--------|---------|
| A、非法使用 | B、破坏信息的完整性 | C、授权侵犯 | D、计算机病毒 |
| A、拒绝服务 | B、陷阱门 | C、旁路控制 | D、业务欺骗 |
| A、特洛伊木马 | B、业务欺骗 | C、物理侵入 | D、业务流分析 |

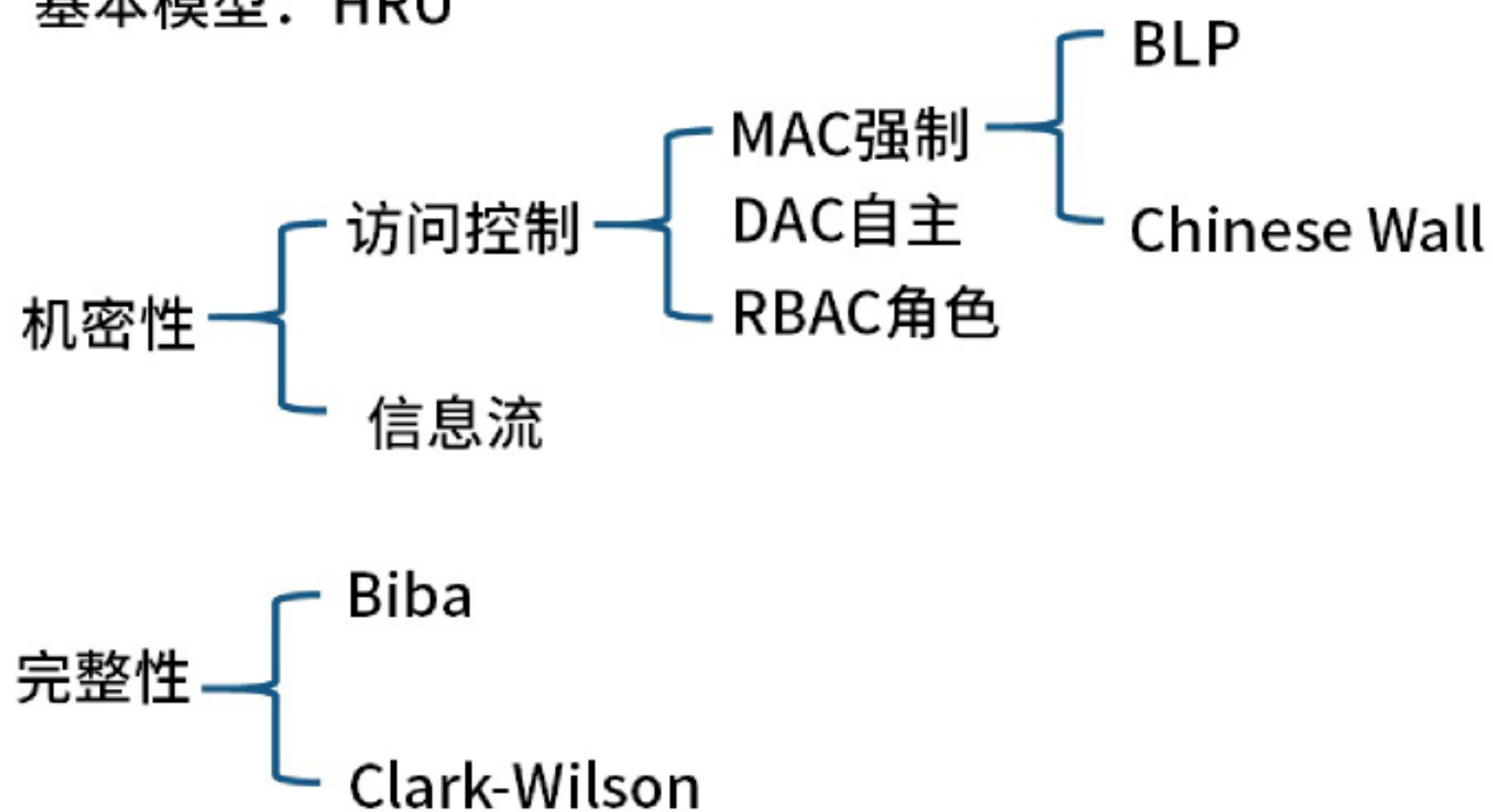


安全模型



◆ 安全模型的分类

基本模型：HRU





安全模型

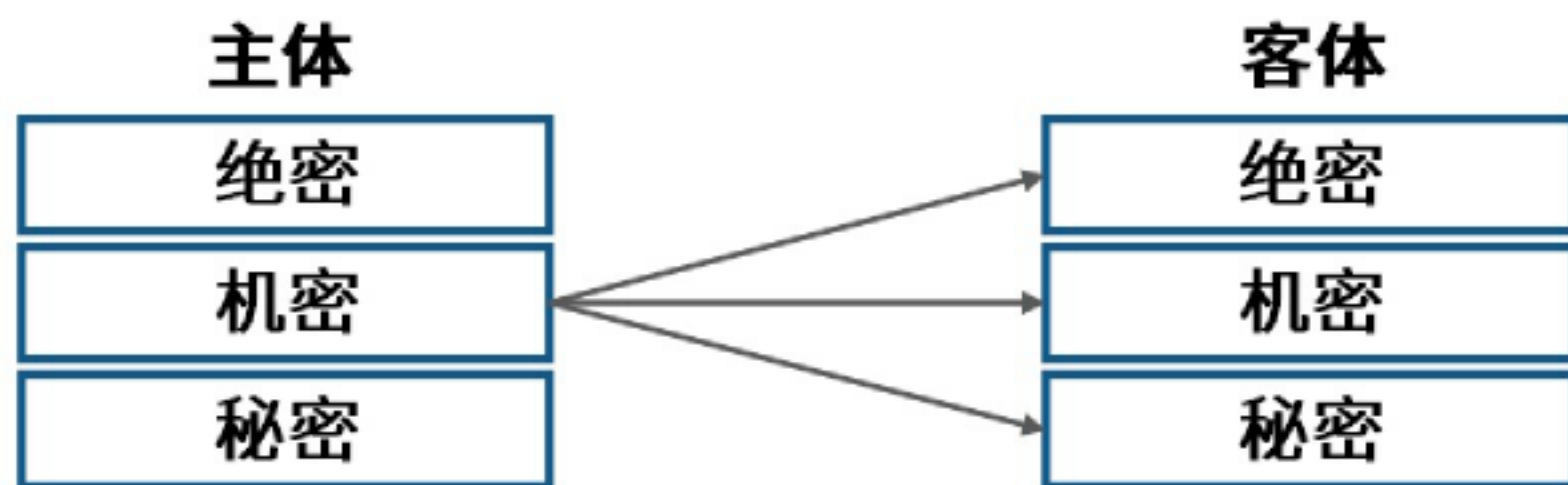


◆ BLP模型

Bell-LaPadula模型是符合军事安全策略的计算机安全模型，简称BLP模型。

BLP模型的安全规则如下：

- 简单安全规则：安全级别**低**的主体**不能**读安全级别**高**的客体；
- 星属性安全规则：安全级别**高**的主体**不能**往**低**级别的客体写；
- 强星属性安全规则：**不允许**对**另一级别**进行读写；
- 自主安全规则：使用**访问控制矩阵**来定义说明自由存取控制。





安全模型



◆ Biba模型

Biba模型主要用于防止非授权修改系统信息，以保护系统的信息完整性。该模型同BLP模型类似，采用主体、客体、完整性级别描述安全策略要求。Biba模型能够防止数据从低完整性级别流向高完整性级别，其安全规则如下：

- 星完整性规则：表示完整性级别**低**的主体**不能**对完整性级别**高**的客体写数据；
- 简单完整性规则：表示完整性级别**高**的主体**不能**从完整性级别**低**的客体读取数据；
- 调用属性规则：表示一个完整性级别**低**的主体**不能**从级别**高**的客体调用程序或服务。





安全模型



◆ Chinese Wall模型

Chinese Wall模型的安全策略的基础是客户访问的信息不会与当前他们可支配的信息产生冲突。

其访问客体控制的安全规则如下：

- 与主体曾经访问过的信息属于**同一公司数据集合**的信息，即**墙内信息**可以访问；
- 属于一个**完全不同的**利益冲突组的可以访问；
- 主体能够对一个客体进行写的前提是主体**未对**任何**属于其他公司数据集**进行过访问。

定理1：一个主体一旦访问过一个客体，则该主体**只能**访问位于**同一公司数据集**的客体或在**不同利益组**的客体。

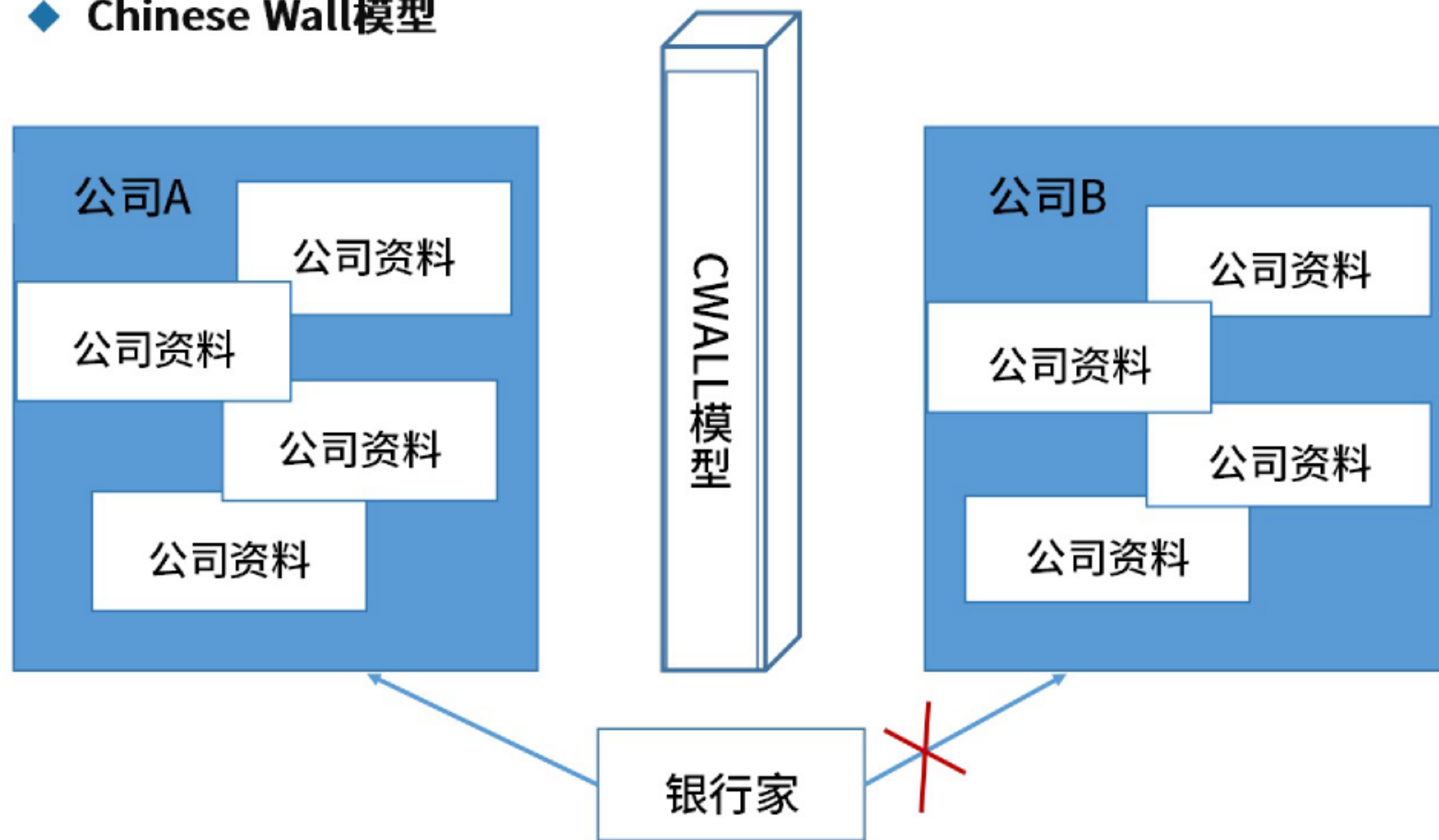
定理2：在一个**利益冲突组**中，一个主体**最多只能**访问一个公司数据集。



安全模型



◆ Chinese Wall模型





习题讲解



Biba模型是属于（ ）。

- A、状态机模型
- B、信息流模型
- C、无干扰模型
- D、完整性模型

BLP模型的设计目标是解决信息系统资源的（ ）保护。

- A、不可否认性
- B、机密性
- C、完整性
- D、匿名性



习题讲解



Bell-LaPadula模型（简称BLP模型）是最早的一种安全模型，也是最著名的多级安全策略模型，BLP模型的简单安全规则是指（ ）。

- A、不可上读
- C、不可下读

- B、不可上写
- D、不可下写



信息安全整体架构设计



◆ WPDRRC模型

WPDRRC模型包括**6个环节**和**3大要素**。

6个环节包括：**预警**、**保护**、**检测**、**响应**、**恢复**和**反击**。模型蕴涵的网络安全能力主要是预警能力、保护能力、检测能力、响应能力、恢复能力和反击能力。

3大要素包括**人员**、**策略**和**技术**。



信息安全整体架构设计



◆ 各模型安全防范功能

	预警	保护	检测	响应	恢复	反击	管理
PDR	无	有	有	有	无	无	无
PPDR	无	有	有	有	无	无	无
PDRR	无	有	有	有	有	无	无
MPDRR	无	有	有	有	有	无	有
WPDRRRC	有	有	有	有	有	有	有



习题讲解



P2DR模型不包括（ ）。

A、防护

B、检测

C、响应

D、预警

加密机制、数据签名机制、访问控制机制、认证机制、信息隐藏、防火墙技术等是属于WPDRRC模型中的（ ）环节。

A、保护

B、检测

C、响应

D、恢复

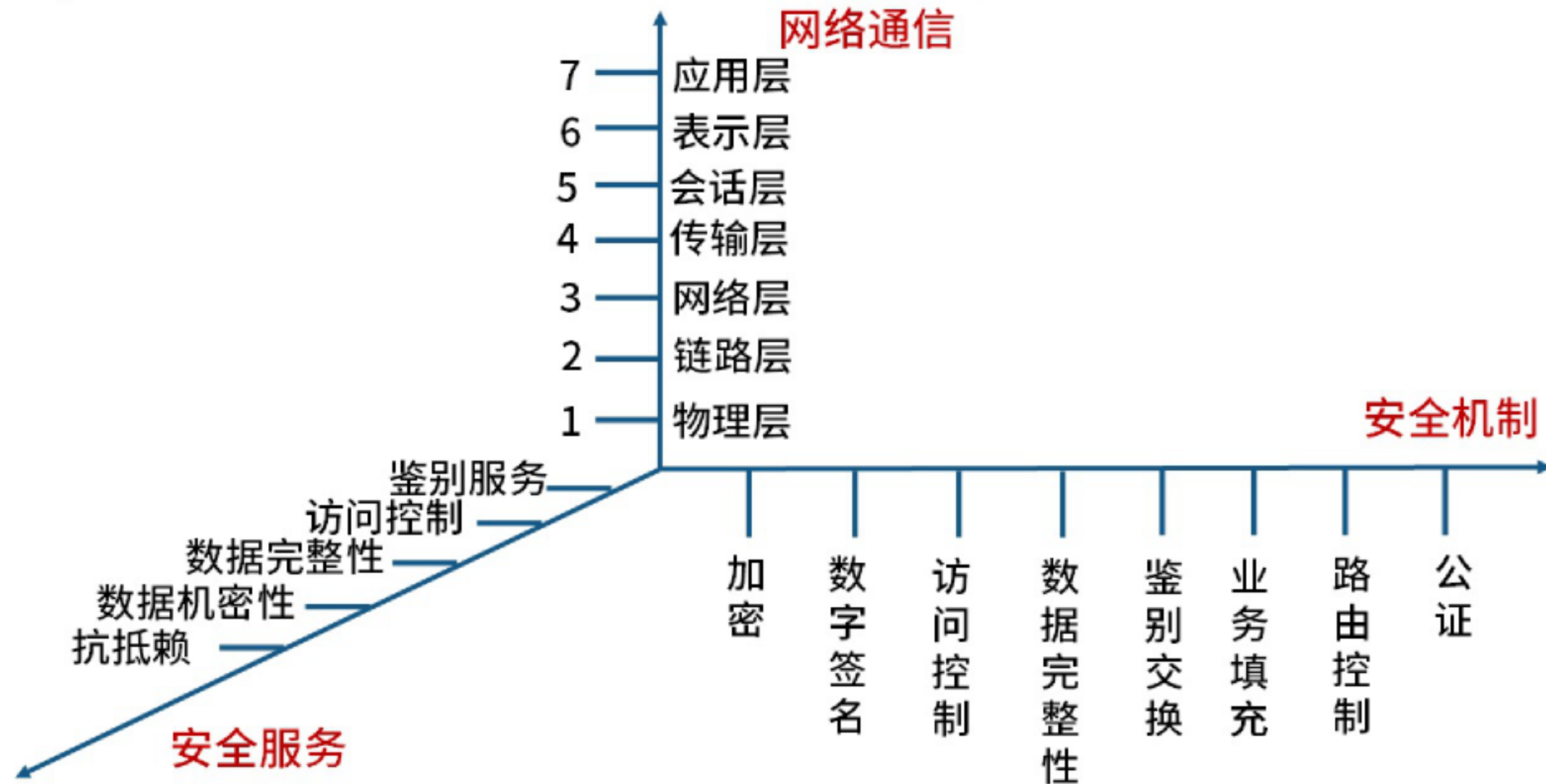


网络安全体系架构设计



◆ 开放系统互联安全体系结构

GB/T 9387.2 – 1995给出了基于OSI参考模型的7层协议之上的信息安全体系结构。

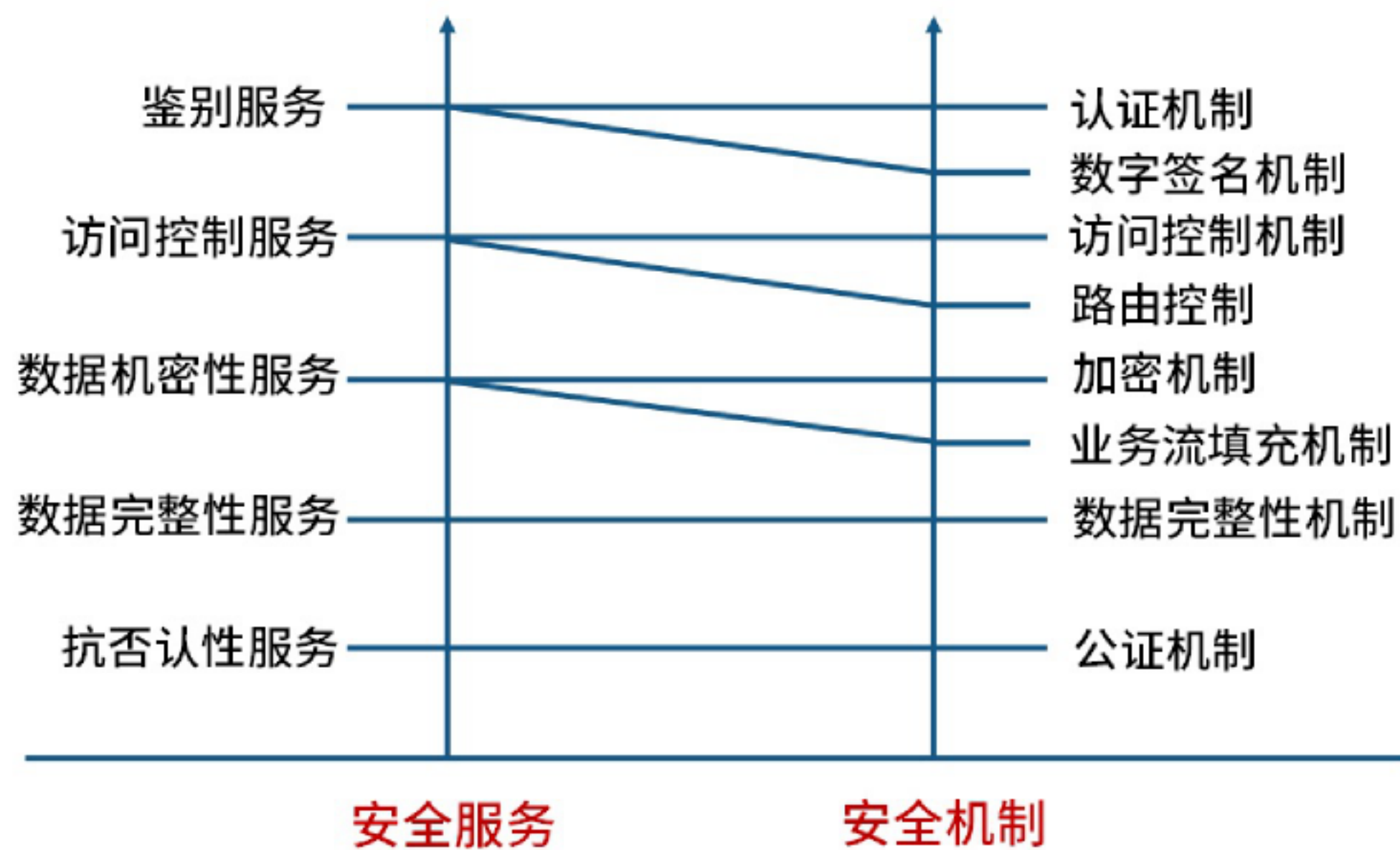




网络安全体系架构设计



◆ 安全服务与安全机制的对应关系





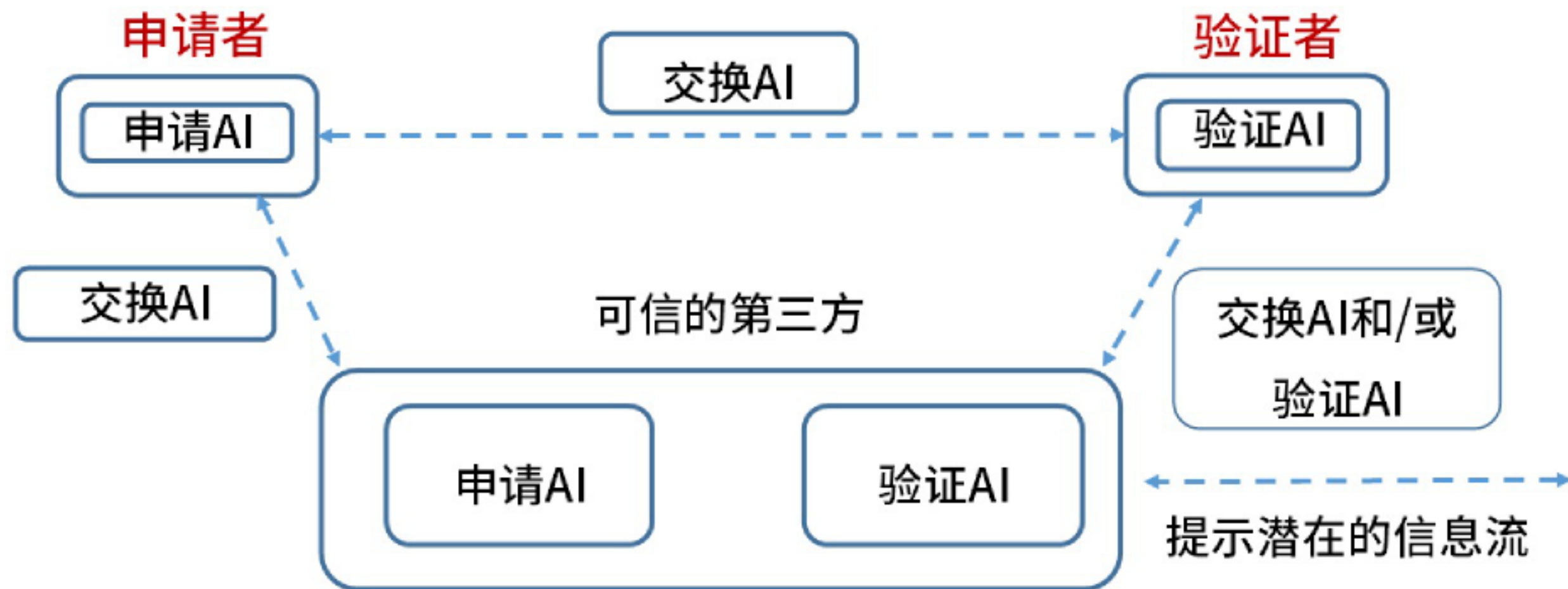
◆ 认证框架

鉴别的基本目的是防止其他实体占用和独立操作被鉴别实体的身份。

鉴别的方式如下：

(1) 已知的；(2) 拥有的；(3) 不改变的特性；(4) 相信可靠的第3方建立的鉴别；(5) 环境。

鉴别信息的类型包括交换鉴别信息、申请鉴别信息和验证鉴别信息。





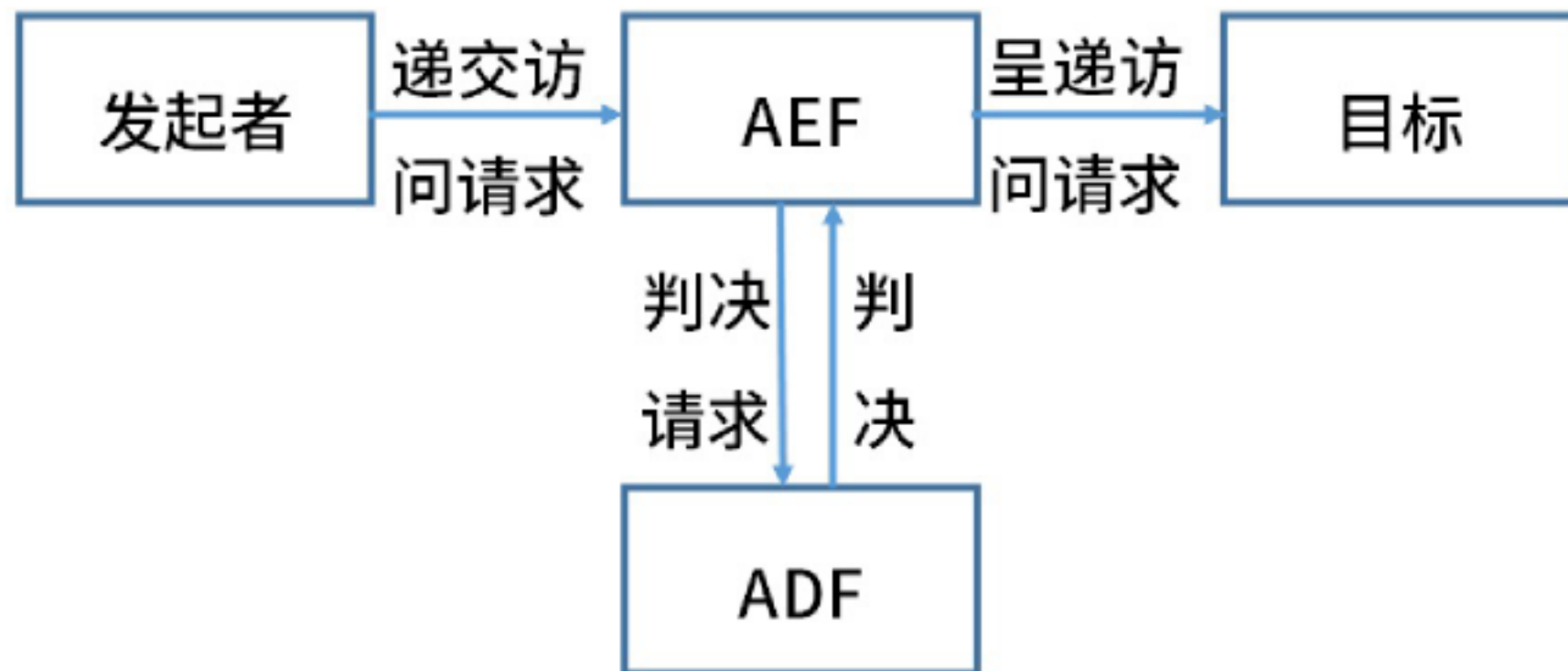
网络安全体系架构设计



◆ 访问控制框架

访问控制决定开发系统环境中允许使用哪些资源，在什么地方适合阻止未授权访问的过程。

基本访问控制功能示意图





网络安全体系架构设计



◆ 机密性框架

机密性服务的目的是确保信息仅仅是对被授权者可用。

机密性机制：

- (1) 通过**禁止访问**提供机密性；
- (2) 通过**加密**提供机密性。

◆ 完整性框架

完整性框架的目的是通过阻止威胁或探测威胁，保护可能遭到不同方式危害的数据完整性和数据相关属性完整性。

完整性机制的类型：

- (1) **阻止对媒体访问**的机制；
- (2) 用以**探测对数据或数据项序列的非授权修改**的机制。



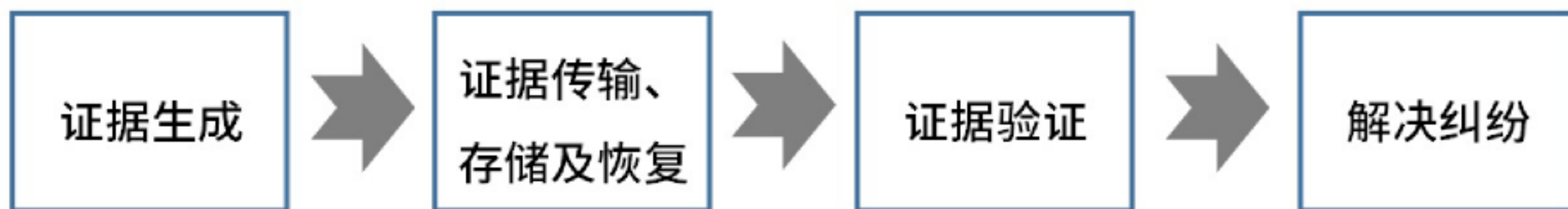
网络安全体系架构设计



◆ 抗抵赖框架

抗抵赖服务包括证据的生成、验证和记录，以及在解决纠纷时随即进行的证据恢复和再次验证。

抗抵赖由4个独立的阶段组成：





习题讲解



保护信息不泄露或不暴露给那些未授权想掌握该信息的实体是（ ）安全服务。

- A、鉴别
- B、数据完整性
- C、数据机密性
- D、访问控制

门禁卡是属于以下哪种鉴别方式？（ ）

- A、已知的
- B、拥有的
- C、不改变的特性
- D、环境



区块链技术



【什么是区块链】

【区块链】 $\neq$ 比特币

比特币底层采用了区块链技术。

比特币交易在我国定性为 **【非法运用】**。



区块链技术



【区块链的特点】

去中心化：由于使用分布式核算和存储，不存在中心化的硬件或管理机构，任意节点的权利和义务都是均等的，系统中的数据块由整个系统中具有维护功能的节点来共同维护。

开放性：系统是开放的，如：区块链上的【交易信息是公开的】，不过【账户身份信息是高度加密的】。

自治性：区块链采用基于协商一致的规范和协议（比如一套公开透明的算法），使得整个系统中的所有节点能够在信任的环境自由安全的交换数据，使得对“人”的信任改成了对机器的信任，任何人为的干预不起作用。

安全性（信息不可篡改）：数据在多个结点存储了多份，篡改数据得改掉51%结点的数据，这太难。同时，还有其它安全机制，如：比特币的每笔交易，都由付款人用私钥签名，证明确实是他同意向某人付款，其它人无法伪造。

匿名性（去信任）：由于节点之间的交换遵循固定的算法，其数据交互是无需信任的（区块链中的程序规则会自行判断活动是否有效），因此交易对手无须通过公开身份的方式让对方对自己产生信任，对信用的累积非常有帮助。

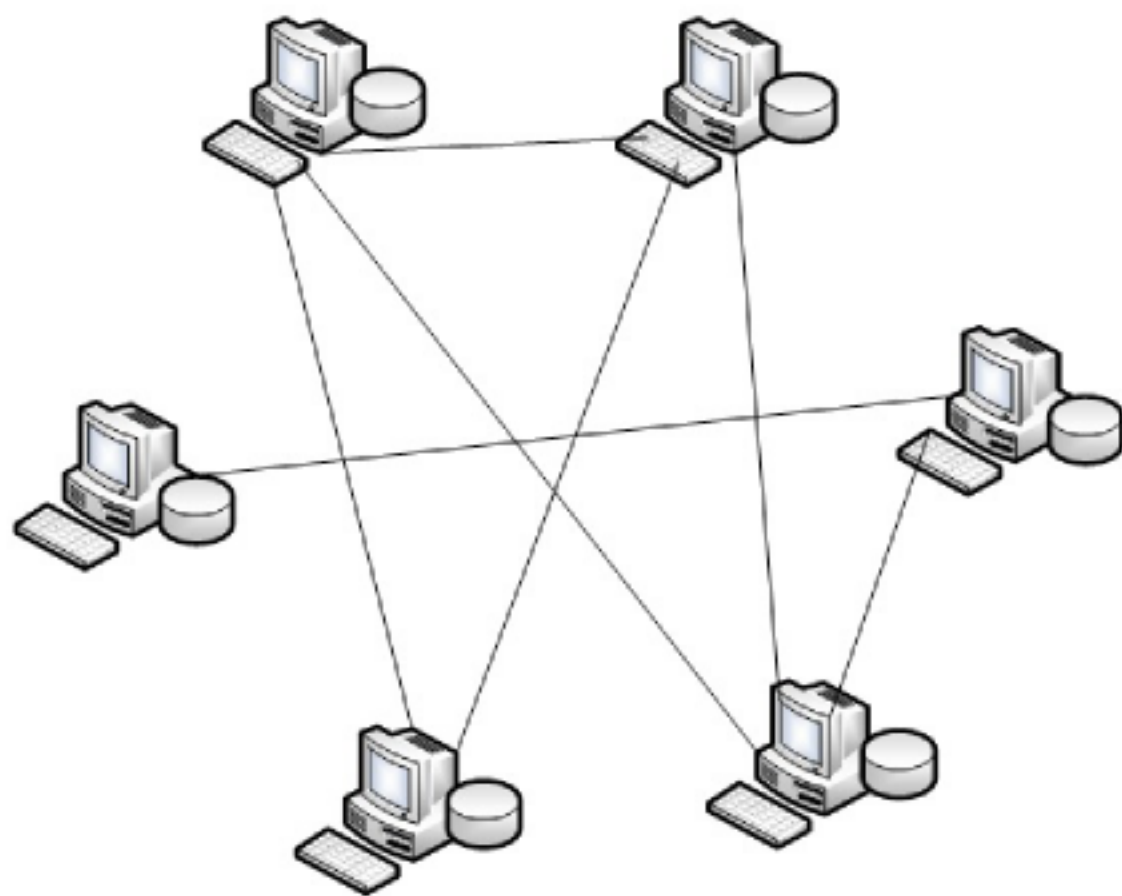
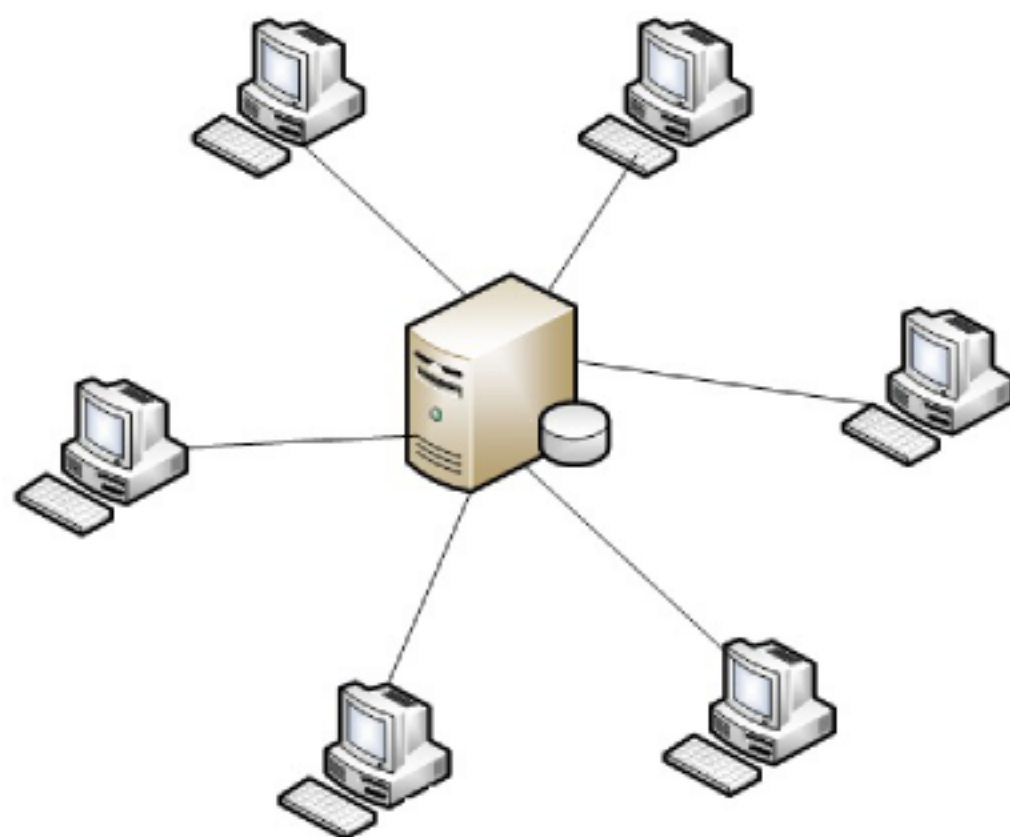


区块链技术



【去中心化】

区块链是一个分布式账本，一种特殊的分布式数据库。



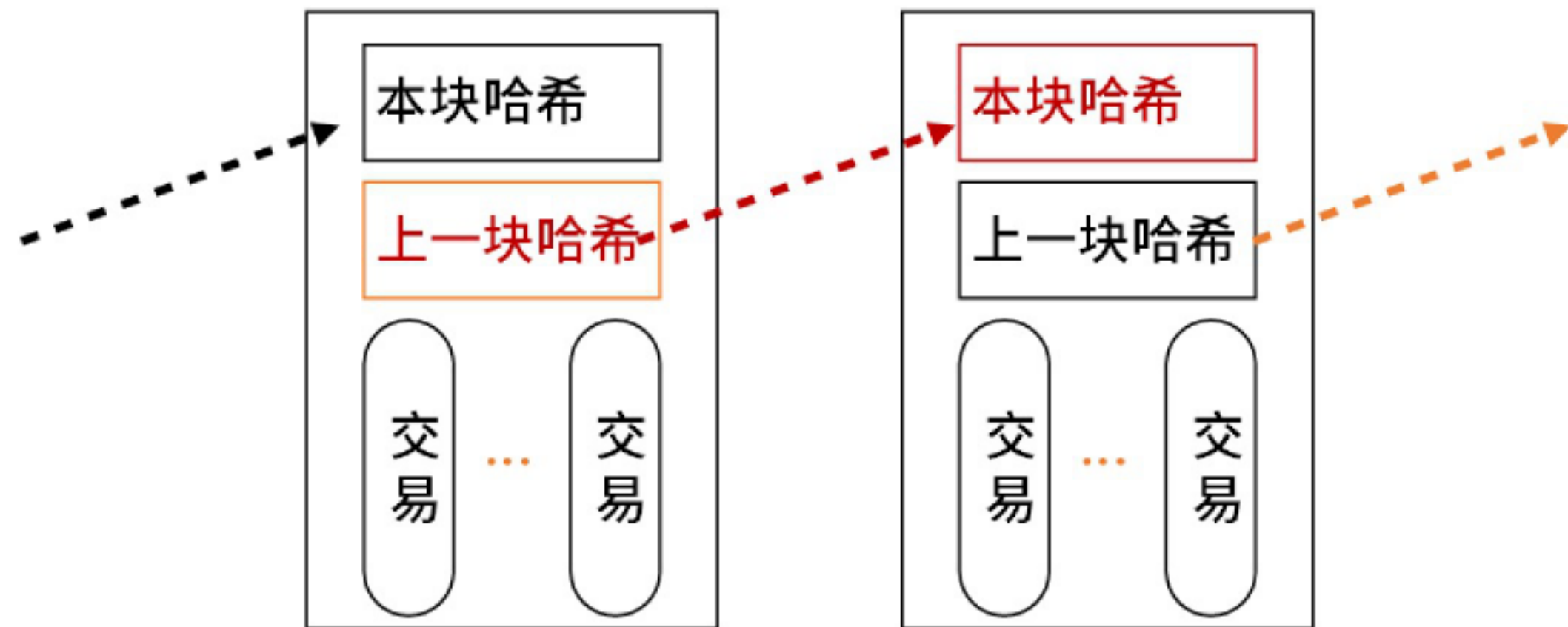
- 1、链表在多个结点存储，没有中心结点，数据不一致时，以“少数服从多数”原则执行。
- 2、所以要篡改成功，除非篡改51%的结点。



区块链技术



【哈希加密/防篡改】





区块链技术



【共识算法（博弈论）/全民记账】

一般有：PoW（工作量证明）、PoS（权益证明）、DPoS（股份授权证明机制）

比特币采用了PoW（工作量证明）：
争夺记账权 = 挖矿

计算出来的账单结点哈希值前13个字符为0，则符合规则，得到记账权。
有一个结点计算出结果，则广播消息告知其它结点，其它结点更新数据。

计算困难，但验证却很容易，例如：
 $218903 =$ 哪两个质数的乘积？

$457 * 479$



区块链技术



【区块链分类】

公有链 (PublicBlockChains)

无官方组织及管理机构，无中心服务器，参与的节点按照系统规则自由接入网络、不受控制，节点间基于共识机制开展工作。

公有链包括比特币、以太坊、超级账本、大多数山寨币以及智能合约，其中公有链的始祖是比特币区块链。

私有链 (PrivateBlockChains)

建立在某个企业内部，系统的运作规则根据企业要求进行设定，修改甚至是读取权限仅限于少数节点，同时仍保留着区块链的真实性和部分去中心化的特性。

联盟链 (ConsortiumBlockChains)

由若干机构联合发起，介于公有链和私有链之间，兼具部分去中心化的特性。



习题讲解



以下关于区块链应用系统中“挖矿”行为的描述中，错误的是（ ）。

- A、矿工“挖矿”取得区块链的记账权，同时获得代币奖励
- B、“挖矿”本质上是在尝试计算一个Hash碰撞
- C、“挖矿”是一种工作量证明机制
- D、可以防止比特币的双花攻击



案例分析练习题



随着科技进步、社会发展，尤其是以计算机为代表的信息技术飞速发展，各种信息呈爆炸式发展。计算机及信息技术的应用领域在不断扩展，计算机在政府、企业、民生等各个领域中都得到越来越广泛的应用，安全问题也日益突显。近来火热的区块链技术的核心便是一系列的信息安全技术。

【问题1】（5分）

请从以下选项中选出与区块链相关的技术，最多选5个，多选不得分。

- A. 对称加密 B. 非对称加密 C. 时间戳 D. 哈希函数 E. 数字信封 F. 数字证书
H. 二维表结构 I. 智能合约 J. CA认证 K. POS

【问题2】（8分）

(1) 属于哈希算法，哈希算法作用包括 (2) 。

- A. 3DES B. PGP C. MD5 D. RSA (2048) E. SHA F. IDEA G. 用于保障信息完整性
H. 用于保障信息可用性 I. 用于信息加密 J. 用于数字签名 K. 用于防篡改

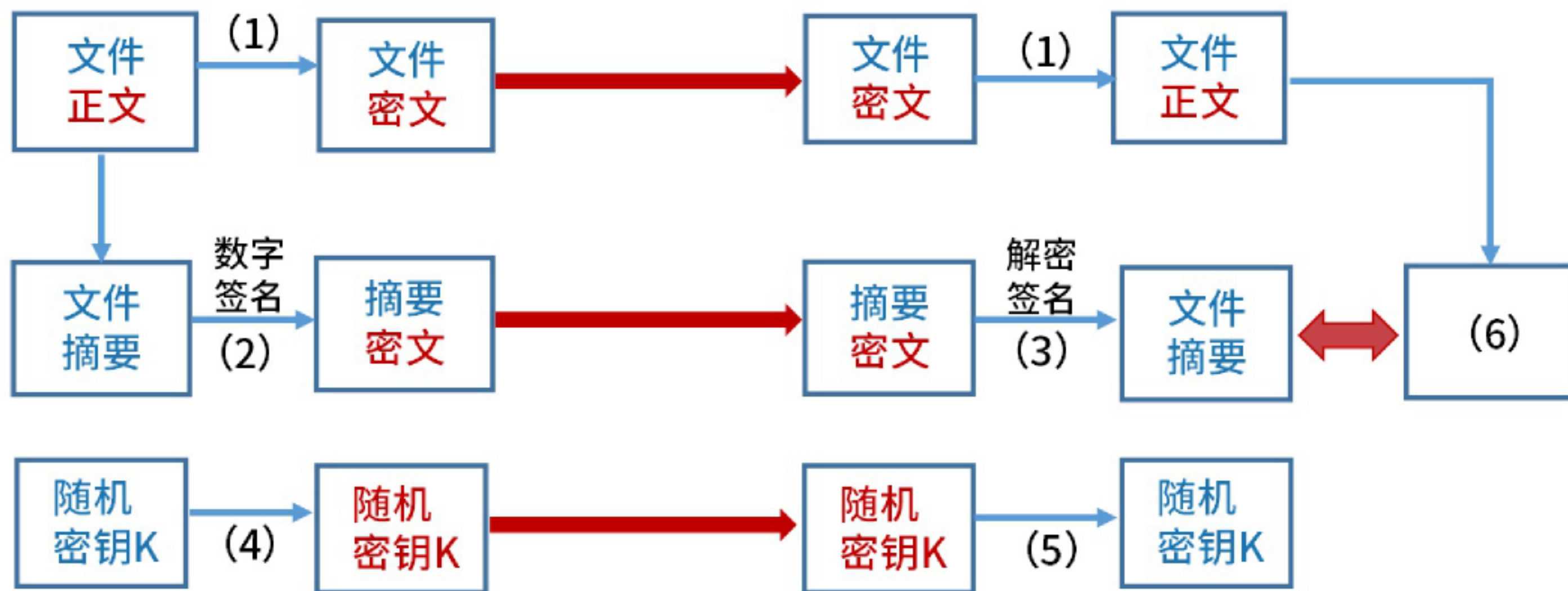


案例分析练习题



【问题3】（12分）

某军区要架设一套内部文件安全传输系统，该文件以加密方式传输，支持最大2G的单个文件传输，为保障安全可靠，发送者不可抵赖发送过的文件，若文件被第三方截获，第三方无法解密也无法篡改其内容。根据此需求，架构设计师王工设计了如下的安全架构：





案例分析练习题



请用以下选项补充图中缺失部分：

- (a) 发送方公钥Pa
- (b) 发送方私钥Sa
- (c) 接收方公钥Pb
- (d) 接收方私钥Sb
- (e) 随机密钥K
- (f) 文件密文
- (g) 文件摘要



案例分析练习题



【参考答案】

【问题1】

B、C、D、I、K

【问题2】

(1) C、E (2) G、K

【问题3】

序号	答案
----	----

(1)	(e)
-----	-----

(2)	(b)
-----	-----

(3)	(a)
-----	-----

(4)	(c)
-----	-----

(5)	(d)
-----	-----

(6)	(g)
-----	-----



案例分析练习题



阅读下列说明，回答问题1至问题3，将解答填入答题纸的对应栏内。

【说明】

访问控制是保障信息系统安全的主要策略之一，其主要任务是保证系统资源不被非法使用和非常规访问。访问控制规定了主体对客体访问的限制，并在身份认证的基础上，对用户提出的资源访问请求加以控制。

【问题1】（6分）

针对信息系统的访问控制包含哪三个基本要素？

【问题2】（7分）

BLP模型是一种强制访问控制模型，请问：

- (1) BLP模型保证了信息的机密性还是完整性？
- (2) BLP模型采用的访问控制策略是上读下写还是下读上写？



案例分析练习题



【问题3】（12分）

ISO安全体系结构包含的安全服务有：①鉴别服务；②访问控制服务；③数据保密性服务；④数据完整性服务；⑤抗否认性服务。请问：

- (1) 针对跨站伪造请求攻击可以采用哪种安全服务来解决或者缓解？
- (2) 针对口令明文传输漏洞攻击可以采用哪种安全服务来解决或者缓解？
- (3) 针对签名伪造攻击可以采用哪种安全服务来解决或者缓解？
- (4) 如果下载的软件被植入木马，可以采用哪种安全服务来进行解决或者缓解？